

PRÁCTICA RA1

Auditoría preventiva del puesto con WinAudit y Greenbone/OpenVAS

Módulo 5021 · Incidentes de ciberseguridad

Duración prevista: 4 horas: 2 h para WinAudit + 2 h para Greenbone/OpenVAS . La instalación y la primera sincronización de feeds deben prepararse antes de la sesión o realizarse fuera del tiempo de práctica, porque pueden prolongarse. Trabajo individual o por parejas.

Elemento	Descripción
Resultado de aprendizaje	RA1. Desarrolla planes de prevención y concienciación en ciberseguridad, estableciendo normas y medidas de protección.
Criterios trabajados	RA1-a (principios generales), RA1-b (protección del puesto) y, de forma principal, RA1-e (auditoría del cumplimiento del plan de prevención y concienciación).
Herramientas	WinAudit (Windows) + Greenbone Community Edition/OpenVAS Scanner (Kali Linux).
Producto final	Informe WinAudit + informe de vulnerabilidades Greenbone + matriz de correlación + auditoría de cumplimiento y medidas priorizadas.
Competencia central	Correlacionar inventario local y análisis de vulnerabilidades sin confundir hallazgo automático, vulnerabilidad confirmada, riesgo y cumplimiento.

Versión 3 · Documento del alumno + instalación + práctica integrada + anexo final con resolución detallada · Política corporativa GalileoTechSolutions

1. Finalidad de la práctica

En una organización, una política de seguridad define cómo debe estar protegido un puesto de trabajo. Sin embargo, una política solo es útil si puede comprobarse. Esta práctica introduce al alumnado en la auditoría básica de cumplimiento mediante WinAudit, una herramienta que recopila información del sistema y genera un inventario técnico del equipo.

La idea clave es trabajar con tres niveles claramente separados:

Nivel	Pregunta	Ejemplo
Requisito	¿Qué exige la política?	“Solo debe existir software autorizado”.
Evidencia	¿Qué datos reales obtenemos?	WinAudit muestra la relación de programas instalados.
Conclusión	¿Cumple o no cumple?	Se compara la lista real con la lista autorizada y se documentan desviaciones.

Principio de auditoría: WinAudit no decide por sí solo si un equipo es seguro. La herramienta recopila evidencias. La conclusión de cumplimiento requiere interpretar esas evidencias frente a requisitos previamente definidos.

2. Objetivos de aprendizaje

- Comprender cómo una política de seguridad se traduce en controles verificables sobre un puesto de trabajo.
- Obtener evidencias técnicas mediante WinAudit sin modificar deliberadamente la configuración del equipo.
- Analizar usuarios, software, servicios, sistema operativo, red y otros elementos básicos del puesto.
- Distinguir entre cumplimiento, incumplimiento y situación no verificable.
- Priorizar desviaciones según su impacto y proponer medidas correctoras proporcionadas.
- Elaborar un informe breve, claro, trazable y reproducible.

3. Recursos necesarios y condiciones

- Equipo Windows de laboratorio o máquina virtual.
- WinAudit disponible en el equipo. Se recomienda ejecutarlo con los permisos de administrador.
- Carpeta de trabajo para guardar el informe generado y el documento de entrega.
- No es necesario realizar cambios en el sistema: la práctica es de observación, recopilación y evaluación.
- Si se trabaja sobre un equipo compartido, no se incluirán datos personales innecesarios en el informe final.

Precaución: No desinstales programas, no detengas servicios, no cambies usuarios, no alteres el firewall ni modifiques la configuración. Primero se audita; después, en un escenario real, las correcciones se aprobarían y aplicarían siguiendo el procedimiento de la organización.

4. Escenario de trabajo

Formas parte del equipo de ciberseguridad de una pequeña organización. Se ha definido una política mínima de protección para los puestos Windows. Debes comprobar, mediante WinAudit y observación controlada, si el equipo asignado cumple los requisitos.

4.1. Política corporativa de referencia · GalileoTechSolutions

La auditoría se realizará tomando como referencia el siguiente Manual Integral de Políticas de Seguridad de la Información. Este documento representa el estado esperado por la organización. El alumnado deberá distinguir entre requisitos que pueden verificarse con WinAudit, requisitos que pueden contrastarse mediante Greenbone/OpenVAS y controles que requieren otras fuentes de evidencia (GPO, consola de identidad, inspección física, revisión documental, registros o entrevistas).

Regla de auditoría: una herramienta no sustituye a la política. La política define qué debe cumplirse; las herramientas aportan evidencias. Si una cláusula no puede verificarse con la evidencia disponible, debe marcarse como “No verificable con estas herramientas”, no como “Cumple”.

4.1.1. Introducción y alcance

- **Propósito:** establecer el marco normativo integral para proteger la confidencialidad, integridad y disponibilidad de los activos de información de GalileoTechSolutions.
- **Alcance:** aplica a todos los empleados, directivos, contratistas, proveedores y cualquier tercero con acceso a las instalaciones, sistemas, redes o datos corporativos.
- **Obligatoriedad:** el desconocimiento de estas políticas no exime de su cumplimiento. Todos los usuarios deben firmar el Acuerdo de Confidencialidad (NDA) y el acuse de recibo de este manual antes de recibir sus credenciales.

4.1.2. Roles y responsabilidades

- **Comité de Seguridad de la Información (CSI):** responsable de aprobar, revisar anualmente y garantizar la aplicación de este documento.
- **Departamento de TI/Ciberseguridad:** encargado de implementar las medidas técnicas (firewalls, antivirus, políticas de grupo), realizar auditorías y monitorizar el cumplimiento.
- **Usuarios finales:** responsables de utilizar los recursos de forma ética, aplicar las medidas de seguridad diarias y reportar cualquier anomalía.

4.1.3. Política de uso aceptable (AUP) y operatividad del empleado

Uso del correo electrónico e Internet

- El correo electrónico corporativo es de uso exclusivamente profesional. Queda prohibido su uso para registrarse en servicios personales, redes sociales no corporativas o plataformas de ocio.
- Se prohíbe el reenvío automático o manual de correos electrónicos corporativos, documentos o datos de clientes a cuentas de correo personales (por ejemplo, Gmail u Outlook personal).
- La navegación web está sujeta a filtrado de contenidos. Está prohibido acceder a sitios de intercambio de archivos (P2P), pornografía, juegos de azar o sitios conocidos por distribuir malware.

Mesas limpias y pantallas limpias

- **Mesas limpias:** al finalizar la jornada laboral no deben quedar documentos impresos con información confidencial, notas con contraseñas ni dispositivos extraíbles a la vista. Todo debe guardarse en cajoneras con llave.
- **Pantallas limpias:** los usuarios deben bloquear manualmente su sesión (Windows + L o Ctrl + Cmd + Q) siempre que abandonen su puesto de trabajo, incluso durante un periodo breve.

Uso de dispositivos móviles y almacenamiento

- Queda estrictamente prohibido conectar dispositivos USB personales (pendrives, discos duros o teléfonos móviles para transferencia de datos) a los equipos corporativos.
- Cualquier transferencia de archivos hacia o desde el exterior debe realizarse mediante las plataformas en la nube autorizadas por la empresa (por ejemplo, OneDrive for Business o SharePoint), con auditoría de accesos y escaneo antimalware.

4.1.4. Gestión de identidades y control de acceso

- Credenciales: las contraseñas son personales e intransferibles. Compartir credenciales con compañeros, superiores o personal de soporte técnico constituye una infracción grave.
- Complejidad: toda contraseña debe tener una longitud mínima de 14 caracteres, combinando letras mayúsculas y minúsculas, números y símbolos.
- Rotación e historial: las contraseñas deben cambiarse cada 90 días. El sistema recordará las últimas 10 contraseñas para evitar su reutilización.
- Autenticación multifactor (MFA): es obligatoria para acceder a cualquier servicio expuesto a Internet (correo web, VPN y portales corporativos).
- Principio de mínimo privilegio: los usuarios operarán exclusivamente con cuentas estándar. Las cuentas con privilegios de Administrador Local o de Dominio solo se usarán por el personal de TI para tareas específicas y de forma auditada.

4.1.5. Configuración segura de puestos de trabajo (hardening)

Estas métricas constituyen la referencia técnica para las auditorías de cumplimiento y para interpretar las evidencias obtenidas en la práctica.

- Cifrado: todos los discos duros de equipos portátiles y de sobremesa deben estar cifrados mediante BitLocker o FileVault. No se pueden almacenar datos corporativos en particiones no cifradas.
- Bloqueo automático: el sistema operativo bloqueará automáticamente la sesión tras un máximo de 10 minutos de inactividad del teclado o ratón.
- Restricción de puertos y protocolos: Telnet, FTP, TFTP, SMBv1 y RDP sin Autenticación a Nivel de Red (NLA) deben permanecer desactivados mediante Políticas de Grupo (GPO).
- Antimalware/EDR: la protección de endpoints debe permanecer activa y con actualizaciones automáticas. Los usuarios no tienen permisos para detener o alterar este servicio.

4.1.6. Gestión de vulnerabilidades y actualizaciones

- Auditorías periódicas: el Departamento de TI ejecutará escaneos de vulnerabilidades autenticados mensualmente utilizando plataformas como Nessus u OpenVAS para verificar la postura de seguridad de cada equipo en red.
- Gestión de parches: el sistema operativo y las aplicaciones de terceros (navegadores, lectores PDF y ofimática) recibirán actualizaciones automáticas forzadas. Los usuarios no pueden retrasar un reinicio por actualización crítica más de 48 horas.
- Tiempos de remediación (SLA): vulnerabilidades críticas (CVSS 9.0–10.0), 48 horas; altas (CVSS 7.0–8.9), 7 días; medias (CVSS 4.0–6.9), 30 días.

4.1.7. Trabajo en remoto y teletrabajo

- El acceso a la red interna desde el exterior solo está permitido a través de la VPN corporativa, utilizando certificados digitales y MFA.
- Está prohibido conectarse a redes Wi-Fi públicas o abiertas (aeropuertos, cafeterías, etc.) sin establecer inmediatamente la conexión VPN.
- No está permitido utilizar equipos personales (BYOD) para procesar, almacenar o transmitir información corporativa sin la instalación previa de la solución de Gestión de Dispositivos Móviles (MDM) de la empresa.

4.1.8. Clasificación y manejo de la información

La información de la empresa se clasifica en tres niveles que determinan las medidas de protección aplicables:

- Pública: información disponible para el público general, como material de marketing.
- Uso interno: información operativa para empleados cuya divulgación no autorizada puede causar un daño moderado, como manuales internos u organigramas.
- Confidencial/Restringida: información crítica cuya filtración puede causar daño legal, financiero o reputacional grave, como datos personales de clientes, código fuente, planes financieros o contraseñas. Debe transmitirse siempre cifrada.

4.1.9. Gestión de incidentes de seguridad

- Deber de reportar: cualquier usuario que sospeche de un incidente de seguridad (infección, pérdida de equipo, phishing o acceso no autorizado) debe notificarlo inmediatamente al Centro de Soporte (HelpDesk) o a seguridad@techinnovate.com.

- Acción inmediata: ante una sospecha de compromiso, el usuario debe desconectar el equipo de la red (retirar el cable de red o apagar Wi-Fi), pero no apagar el equipo, con el objetivo de preservar evidencia volátil que pudiera ser necesaria para una investigación.

4.1.10. Cumplimiento y régimen disciplinario

- El departamento de TI monitoriza el tráfico de red, el acceso a archivos y la telemetría de los equipos para garantizar el cumplimiento de estas políticas.
- Las violaciones serán investigadas y podrán dar lugar a medidas disciplinarias conforme a la normativa y procedimientos aplicables: amonestación, suspensión u otras medidas, además de las acciones legales que pudieran corresponder.

4.2. De la política corporativa a la baseline auditable

El manual anterior contiene controles técnicos, organizativos, físicos y de comportamiento. Para la práctica se selecciona una baseline operativa que permita trabajar de forma trazable en el tiempo disponible. Los controles P-01 a P-08 se verifican principalmente con WinAudit y comprobaciones locales; los controles P-09 a P-12 se amplían posteriormente con Greenbone/OpenVAS. El resto de cláusulas deben reconocerse y asociarse a la evidencia que correspondería en una auditoría real.

Tipo de requisito	Ejemplos de la política	Fuente de evidencia principal
Inventario/configuración	SO, software, servicios, cuentas, red	WinAudit + comprobaciones locales
Exposición/vulnerabilidades	Servicios expuestos, CVE, severidad, remediación	Greenbone/OpenVAS + validación técnica
Identidad y acceso	MFA, política de contraseñas, privilegios	WinAudit parcialmente; AD/GPO/IdP para validación completa
Controles físicos y comportamiento	Mesa limpia, bloqueo manual, reporte de incidentes	Inspección, observación, simulación o cuestionario
Gobierno y cumplimiento	Roles, revisiones, autorizaciones y evidencias de auditoría	Revisión documental, registros y entrevistas

Para la primera fase de la práctica se utiliza la siguiente baseline simplificada, derivada de la política corporativa:

ID	Área	Requisito de la política	Prioridad
P-01	Sistema operativo	El sistema operativo debe estar identificado, soportado y con actualizaciones de seguridad gestionadas.	Alta
P-02	Cuentas de usuario	Solo deben existir cuentas justificadas. Deben identificarse cuentas administrativas y cuentas anómalas o genéricas.	Alta
P-03	Software	El software instalado debe estar justificado por la función del puesto. No debe existir software claramente ajeno o no autorizado.	Media
P-04	Servicios	Los servicios activos deben responder a una necesidad del sistema o de la organización. Los servicios desconocidos deben revisarse.	Media
P-05	Red	La configuración de red debe estar identificada y documentada. No deben aparecer adaptadores o configuraciones inesperadas sin justificar.	Media
P-06	Seguridad	Deben identificarse las medidas de protección disponibles en el equipo: antivirus/antimalware, firewall y mecanismos equivalentes cuando sean visibles.	Alta
P-07	Actualización e inventario	El puesto debe poder inventariarse y debe existir información suficiente para verificar su configuración básica.	Media
P-08	Principio de mínimo privilegio	Las cuentas y configuraciones privilegiadas deben limitarse a las estrictamente necesarias.	Alta

5. Planificación temporal de la sesión

Tiempo	Actividad
0-10 min	Lectura del escenario, revisión de la baseline y preparación de la carpeta de trabajo.
10-25 min	Ejecución de WinAudit y generación del inventario.
25-65 min	Análisis guiado de las secciones del informe y registro de evidencias.
65-95 min	Matriz de cumplimiento y valoración de desviaciones.
95-110 min	Propuesta de medidas correctoras y priorización.
110-120 min	Redacción de conclusiones, revisión y entrega.

6. Entregables

- Informe exportado por WinAudit (HTML, PDF u otro formato disponible en la versión utilizada), nombrado con el patrón: Apellidos_Nombre_WinAudit.
- Documento de auditoría cumplimentado con la matriz de evidencias y cumplimiento.
- Respuestas a las cuestiones de análisis incluidas en esta práctica.
- Conclusión ejecutiva de 8 a 12 líneas con los principales hallazgos y las tres acciones prioritarias.

7. Desarrollo de la práctica: procedimiento paso a paso

Paso 1. Preparación

1. Crea una carpeta de trabajo específica para la práctica.
2. Anota la fecha y hora de inicio, el nombre asignado al equipo y, si procede, si se trata de equipo físico o máquina virtual.
3. Lee de nuevo la baseline P-01 a P-08. No empieces a interpretar resultados sin saber qué requisitos vas a comprobar.

Paso 2. Ejecución de WinAudit

1. Inicia WinAudit.
2. Espera a que finalice el análisis. Dependiendo de la versión, el programa puede recopilar automáticamente numerosos apartados del sistema.
3. No cierres el informe ni modifiques el equipo. Guarda o exporta el resultado antes de comenzar el análisis detallado.

Importante: Si una sección no aparece en tu versión de WinAudit o la información es incompleta por permisos, no inventes el dato. Marca el control como “No verificable” y explica la causa.

Paso 3. Identificación del sistema

Localiza la información general del sistema operativo y del equipo. Registra, como mínimo: edición/versión de Windows, arquitectura si está disponible, nombre del equipo y cualquier dato relevante sobre actualización o instalación que aparezca en el informe.

Preguntas de análisis:

1. ¿Puedes identificar de forma inequívoca el sistema operativo auditado?
2. ¿La información disponible permite afirmar que el sistema está soportado y actualizado? Si no, ¿qué evidencia adicional necesitarías?
3. ¿Qué riesgo tendría mantener un sistema sin soporte o sin actualizaciones de seguridad?

Paso 4. Cuentas de usuario y privilegios

Localiza la sección de usuarios y grupos. Identifica las cuentas existentes, las cuentas administrativas y cualquier cuenta que resulte genérica, desconocida o aparentemente innecesaria.

No debes concluir que una cuenta es maliciosa solo por su nombre. La auditoría debe señalar qué necesita justificación.

Preguntas de análisis:

1. ¿Cuántas cuentas aparecen? ¿Todas tienen una finalidad evidente?
2. ¿Qué cuentas disponen de privilegios administrativos?
3. ¿Detectas alguna cuenta que deba justificarse, deshabilitarse o revisarse?
4. ¿Cómo se relaciona este análisis con el principio de mínimo privilegio?

Paso 5. Software instalado

Revisa el inventario de aplicaciones. Clasifica los programas observados en tres categorías: claramente necesarios, potencialmente prescindibles y requieren justificación. No basta con copiar la lista de software; debes interpretarla.

Preguntas de análisis:

1. Indica cinco aplicaciones claramente relacionadas con la función del equipo o con el propio sistema.
2. Indica hasta tres aplicaciones que revisarías por ser desconocidas, antiguas o aparentemente innecesarias.
3. ¿Por qué el software innecesario puede aumentar la superficie de ataque?
4. ¿Qué información adicional necesitarías antes de ordenar la desinstalación de un programa?

Paso 6. Servicios y elementos de ejecución

Revisa los servicios que muestre WinAudit. El objetivo no es conocer de memoria todos los servicios de Windows, sino identificar los que requieren validación. Presta atención a nombres poco reconocibles, software de terceros, herramientas de acceso remoto o servicios que no encajen con la función del puesto.

Preguntas de análisis:

1. Selecciona tres servicios y explica brevemente qué función parecen cumplir.
2. ¿Existe algún servicio que deba ser revisado por el administrador? Justifica la respuesta.
3. ¿Por qué detener un servicio durante la auditoría sería una mala práctica?

Paso 7. Configuración de red

Identifica adaptadores, direcciones IP, configuración TCP/IP y cualquier información de red incluida. Debes documentar lo que existe y detectar elementos no esperados, no “adivinar” si una dirección es segura.

Preguntas de análisis:

1. ¿Qué adaptadores de red aparecen?
2. ¿La información es coherente con el tipo de equipo auditado?
3. ¿Detectas adaptadores virtuales, VPN u otros componentes que deban justificarse?
4. ¿Qué dato de red sería especialmente importante documentar en una investigación posterior de incidentes?

Paso 8. Controles de seguridad visibles

Busca evidencias relacionadas con antivirus, antimalware, firewall u otros mecanismos de protección. La visibilidad dependerá de la versión de WinAudit y de los permisos. Si WinAudit no permite confirmar un control, debes indicarlo expresamente y proponer otra fuente de evidencia.

Preguntas de análisis:

1. ¿Puedes demostrar con el informe que existe protección antimalware?
2. ¿Puedes demostrar que existe firewall?
3. ¿Qué diferencia hay entre “la herramienta no lo muestra” y “el control no existe”?
4. Propón una segunda fuente de evidencia para verificar cada uno de esos controles.

Paso 9. Construcción de la matriz de cumplimiento

Para cada requisito P-01 a P-08, selecciona una de las siguientes conclusiones: Cumple, Cumple parcialmente, No cumple o No verificable. La conclusión debe apoyarse siempre en una evidencia y una justificación.

Estado	Cuándo utilizarlo
Cumple	La evidencia disponible demuestra de forma razonable que el requisito se satisface.
Cumple parcialmente	El control existe, pero es incompleto, dudoso o presenta alguna desviación menor.
No cumple	Existe evidencia suficiente de una desviación respecto al requisito.
No verificable	No hay evidencia suficiente. La ausencia de datos no debe confundirse con incumplimiento.

Paso 10. Medidas correctoras y conclusión

Selecciona los tres hallazgos más relevantes y propón una medida correctora para cada uno. La medida debe ser concreta, proporcionada y verificable. Finaliza con una conclusión ejecutiva de 8 a 12 líneas.

8. Hoja de trabajo del alumno

8.1. Datos de la auditoría

Campo	Valor
Alumno/a o pareja	
Fecha y hora	
Equipo / VM	
Versión de WinAudit	
Sistema operativo detectado	
Nombre del fichero exportado	

8.2. Registro de evidencias

Área	Evidencia observada	Interpretación inicial
Sistema operativo		
Usuarios y grupos		
Software		
Servicios		
Red		
Controles de seguridad		

8.3. Matriz de cumplimiento

ID	Evidencia	Estado	Riesgo / impacto	Medida propuesta
P-01				
P-02				
P-03				
P-04				
P-05				
P-06				
P-07				
P-08				

8.4. Hallazgos prioritarios

Prioridad	Hallazgo	Por qué importa	Acción correctora	Cómo comprobar que se ha corregido
1				

Prioridad	Hallazgo	Por qué importa	Acción correctora	Cómo comprobar que se ha corregido
2				
3				

8.5. Conclusión ejecutiva

9. Cuestiones finales de reflexión

1. Explica con tus palabras por qué una herramienta de inventario no puede determinar por sí sola el cumplimiento de una política de seguridad.

2. Diferencia “hallazgo”, “evidencia” y “medida correctora” con un ejemplo obtenido durante la práctica.

3. ¿Por qué la existencia de una cuenta administrativa adicional puede ser un riesgo aunque no haya evidencia de un incidente?

4. ¿Por qué es incorrecto considerar “No cumple” un control que WinAudit no ha podido mostrar?

5. ¿Qué tres evidencias de esta práctica consideras más útiles para una auditoría periódica del puesto?

6. ¿Qué elementos de los revisados podrían convertirse después en indicadores relevantes para detectar o investigar un incidente?

10. Criterios de calidad del informe

- Cada conclusión de cumplimiento está vinculada a una evidencia concreta.
- No se confunde “no visible” con “no existente”.
- Las medidas correctoras son específicas y verificables.
- Los hallazgos están priorizados por riesgo, no por el orden en el que aparecen en la herramienta.
- El informe evita datos personales innecesarios y utiliza terminología técnica adecuada.
- La conclusión ejecutiva resume el estado del puesto sin reproducir todo el inventario.

11. Correspondencia con el RA1

Criterio	Cómo se trabaja en la práctica
RA1-a	Se aplican principios de ciberseguridad como inventario, reducción de superficie de ataque, mínimo privilegio y trazabilidad.
RA1-b	Se comprueba la protección básica del puesto mediante requisitos concretos sobre usuarios, software, servicios, red y controles de seguridad.
RA1-e	Es el eje principal: se comparan requisitos definidos con evidencias obtenidas y se documentan desviaciones, medidas correctoras y seguimiento.
RA1-c / RA1-d	No son el objetivo principal de esta sesión; los hallazgos obtenidos pueden alimentar posteriormente el plan y los materiales de concienciación.

12. · Ampliación: de WinAudit al análisis de vulnerabilidades

La primera parte de la práctica responde a la pregunta “¿qué hay en el equipo y cómo está configurado?”. La ampliación con Greenbone/OpenVAS añade una segunda pregunta: “¿qué debilidades o vulnerabilidades conocidas puede presentar la superficie que el equipo expone?”. Ambas fuentes se correlacionan para realizar una auditoría preventiva más sólida, siempre frente a una política definida previamente.

Idea central de la : WinAudit aporta inventario y contexto local. Greenbone/OpenVAS realiza comprobaciones de vulnerabilidades y exposición desde el punto de vista del escáner. Ninguna herramienta decide por sí sola el riesgo ni el cumplimiento: el alumno debe interpretar, contrastar y justificar.

Fase	Pregunta	Herramienta principal	Producto
1. Inventario	¿Qué sistema, software, servicios, usuarios y red tiene el puesto?	WinAudit	Línea base técnica del puesto.
2. Exposición	¿Qué servicios son visibles desde la red de laboratorio?	Greenbone/OpenVAS	Superficie observable desde el escáner.
3. Vulnerabilidades	¿Qué pruebas de vulnerabilidad producen hallazgos?	Greenbone/OpenVAS	Resultados/NVT, severidad y evidencias.
4. Correlación	¿Coincide lo visto desde fuera con el inventario local?	WinAudit + Greenbone	Hallazgo correlacionado y mejor contextualizado.
5. Cumplimiento	¿Qué requisito de la política se cumple o se desvía?	Criterio del auditor	Matriz de cumplimiento.
6. Mejora	¿Qué debe corregirse y cómo se verificará?	Plan de acción	Medida correctora y revalidación.

12.1. Qué significa OpenVAS dentro de Greenbone

En la documentación actual, OpenVAS es el motor de escaneo de vulnerabilidades que forma parte de Greenbone Vulnerability Management / Greenbone Community Edition. La interfaz web de administración y análisis se conoce como Greenbone Security Assistant (GSA). En Kali Linux, el metapaquete gvm instala los componentes necesarios y proporciona scripts de configuración, comprobación, arranque y parada.

Para esta práctica usaremos la expresión “Greenbone/OpenVAS” para distinguir dos elementos: Greenbone como plataforma de gestión y OpenVAS Scanner como motor que ejecuta las pruebas de vulnerabilidad (VT/NVT).

12.2. Relación específica con el RA1

Criterio RA1	Papel en la
RA1-a	Aplicación de principios preventivos: inventario, reducción de superficie de ataque, gestión de vulnerabilidades, trazabilidad y priorización.
RA1-b	Comprobación de la protección del puesto mediante exposición de servicios, software vulnerable y controles técnicos verificables.
RA1-e	Eje principal de la : se audita el cumplimiento comparando política, evidencia WinAudit y resultados del escáner.
RA1-c / RA1-d	Los hallazgos pueden transformarse después en necesidades y materiales de concienciación, aunque no son el objetivo central de esta sesión.

Límite curricular: En RA1 el escáner se usa con finalidad preventiva y de auditoría. La explotación de vulnerabilidades, la respuesta a un incidente real y el análisis forense profundo se reservan para otros resultados de aprendizaje y prácticas específicas.

13. Entorno de laboratorio y normas de seguridad

La práctica se realizará únicamente sobre equipos o máquinas virtuales indicadas. Un escáner de vulnerabilidades genera tráfico activo y puede provocar alertas, carga o comportamientos inesperados; por ello no debe dirigirse contra redes de terceros ni contra sistemas de producción sin autorización.

Arquitectura recomendada:

Elemento	Configuración recomendada	Función
VM 1 · Windows	El mismo Windows auditado con WinAudit en la V1. Conectado a una red de laboratorio aislada.	Objetivo autorizado.
VM 2 · Kali Linux	Greenbone/OpenVAS instalado. Puede disponer de un adaptador NAT para actualizar feeds y otro adaptador de red de laboratorio.	Escáner.
Red de laboratorio	Host-only / red interna del hipervisor. Ejemplo didáctico: 192.168.56.0/24.	Evita escanear accidentalmente la red real.
Snapshot	Instantánea antes de empezar, especialmente del objetivo Windows.	Permite volver al estado inicial y repetir la auditoría.

Regla de autorización: Solo se escaneará la IP asignada en el laboratorio. No se introducirán rangos, dominios o direcciones externas. Si la IP no coincide con la máquina objetivo, se detendrá la actividad y se verificará la topología antes de continuar.

Antes de escanear, el alumno registrará la IP del Windows objetivo mediante una fuente autorizada (por ejemplo, la configuración de red del propio sistema). El ping puede servir como comprobación auxiliar, pero que no haya respuesta ICMP no demuestra que el host esté apagado: el firewall puede bloquearla.

14. Instalación de Greenbone/OpenVAS en Kali Linux

Existe como alternativa, Greenbone Community Edition, una herramienta fantástica y robusta para estudiantes, laboratorios, aulas o pequeñas empresas que tienen el conocimiento técnico para gestionarla por sí mismos

14.1. Actualizar Kali Linux

Desde una terminal de Kali Linux, actualiza los índices de paquetes y aplica las actualizaciones pendientes. En un entorno docente conviene crear antes una instantánea de la VM.

```
sudo apt update  
sudo apt upgrade -y
```

14.2. Instalar el metapaquete GVM

Kali proporciona el metapaquete gvm, que instala Greenbone Vulnerability Manager, OpenVAS Scanner y los componentes necesarios de la interfaz y los servicios asociados.

```
sudo apt install gvm -y
```

14.3. Configuración inicial

Ejecuta el asistente automático. Durante el proceso se crean certificados, base de datos, usuario administrador y se inicia la sincronización de los feeds. Debes guardar la contraseña generada para el usuario admin.

```
sudo gvm-setup
```

Muy importante: Anota la contraseña del usuario admin que aparece al finalizar gvm-setup. No la incluyas en capturas ni en el informe que vaya a compartirse.

14.4. Comprobar la instalación

Cuando termine la configuración, ejecuta la comprobación. Si aparecen líneas marcadas como FIX o ERROR, no continúes con el escaneo hasta resolverlas. El script de Kali suele indicar la acción correctora correspondiente.

```
sudo gvm-check-setup
```

14.5. Arrancar y detener los servicios

```
sudo gvm-start  
# Para detener los servicios al terminar:  
sudo gvm-stop
```

Tras el arranque, la interfaz web local suele quedar disponible en:

```
https://127.0.0.1:9392
```

El navegador puede advertir de un certificado autofirmado en el laboratorio. El alumno debe comprobar que está accediendo a 127.0.0.1 y no a una dirección desconocida antes de continuar.

14.6. Estado de los feeds

Greenbone utiliza feeds de pruebas de vulnerabilidad y datos como CVE/CPE. No se iniciará la práctica hasta que la interfaz muestre que los feeds han terminado de cargarse o que el sistema está preparado. La primera sincronización e importación puede prolongarse considerablemente.

Si se entrega una VM preconfigurada, bastará con arrancar los servicios, iniciar sesión y comprobar el estado de los feeds antes de crear el primer objetivo.

14.7. Incidencias frecuentes de instalación

Síntoma	Interpretación	Actuación
gvm-check-setup muestra ERROR/FIX	La instalación o una dependencia no está completa.	Seguir la corrección que muestra el propio script y volver a ejecutar gvm-check-setup.
No aparecen configuraciones como "Full and fast"	Los objetos de datos/feeds pueden no haberse importado todavía.	Esperar a que finalice la sincronización e importación y revisar el estado de los feeds.
No se recuerda la contraseña admin	No puede iniciarse sesión con la credencial generada.	Se debe restablecer o recrear la credencial siguiendo el procedimiento de administración; no compartir contraseñas entre grupos.
La interfaz no abre	Los servicios pueden no estar iniciados o seguir cargando.	Ejecutar gvm-start y comprobar de nuevo la instalación.
El objetivo aparece como no disponible	Puede existir un problema de red, firewall o prueba de vida.	Verificar IP, adaptadores y conectividad del laboratorio antes de cambiar opciones de detección.

15. Práctica · Auditoría de vulnerabilidades con Greenbone/OpenVAS

Duración de esta parte: Aproximadamente 2 horas con Greenbone ya instalado y los feeds preparados. El tiempo real del escaneo depende de la VM, de los recursos disponibles y del número de servicios visibles.

15.1. Objetivo

Analizar desde la red de laboratorio el mismo puesto Windows estudiado con WinAudit, obtener un informe de vulnerabilidades y correlacionar ambos resultados para mejorar la auditoría de cumplimiento. El objetivo no es explotar fallos, sino identificar y documentar exposición, hallazgos y medidas preventivas.

15.2. Ampliación de la baseline

ID	Área	Requisito de la política	Prioridad
P-09	Servicios expuestos	Los servicios accesibles desde red deben estar justificados y corresponder con la función del puesto.	Alta
P-10	Vulnerabilidades conocidas	Los hallazgos de severidad relevante deben revisarse, validarse y disponer de un tratamiento documentado.	Alta
P-11	Priorización	Las acciones correctoras deben priorizarse considerando severidad técnica, exposición, activo y contexto; no solo el número de hallazgos.	Alta
P-12	Verificación	Tras una corrección, debe existir una comprobación posterior que permita demostrar si el hallazgo ha desaparecido o ha sido aceptado justificadamente.	Media

15.3. Paso 1 · Recuperar la evidencia de WinAudit

1. Abre el informe WinAudit generado en la V1.
2. Selecciona entre tres y cinco elementos que puedan tener relación con la superficie de ataque: servicios, software servidor, herramientas de acceso remoto, configuración de red o aplicaciones antiguas.
3. Registra la evidencia concreta: nombre del software/servicio, versión si aparece y motivo por el que quieres comprobarlo con el escáner.

Elemento WinAudit	Evidencia local	Hipótesis que se comprobará con Greenbone
1		
2		
3		
4		
5		

15.4. Paso 2 · Identificar el objetivo autorizado

1. En Windows, anota la dirección IP del adaptador perteneciente a la red de laboratorio.
2. Comprueba que la dirección pertenece al segmento indicado.
3. En Kali, verifica que existe conectividad de red con el segmento. No escanees todavía.
4. Registra la IP exacta que se utilizará como objetivo.

Control previo obligatorio: Antes de crear el objetivo, se debe verificar que la IP pertenece realmente a la VM Windows autorizada. Una dirección escrita incorrectamente puede provocar el escaneo de otro dispositivo.

15.5. Paso 3 · Crear el Target en Greenbone

1. Abre Greenbone Security Assistant e inicia sesión.
2. Accede al apartado de Targets/Objetivos (la ubicación exacta del menú puede variar ligeramente según la versión).
3. Crea un objetivo con un nombre identificable, por ejemplo: WIN-RA1-APELLIDOS.
4. Introduce únicamente la IP autorizada del Windows de laboratorio.
5. Mantén la lista de puertos o configuración. No introduces rangos adicionales.
6. Guarda el objetivo y captura o registra su nombre e IP para el informe.

15.6. Paso 4 · Crear y ejecutar la tarea de escaneo

1. Crea una nueva tarea de escaneo asociada al Target anterior.
2. Selecciona la configuración "Full and fast" cuando esté disponible.
3. Usa el OpenVAS Scanner configurado por defecto.
4. Inicia la tarea y observa su progreso sin lanzar tareas duplicadas.
5. Cuando finalice, abre el informe generado y registra fecha, hora y estado del escaneo.

No explotación: No utilices módulos de explotación ni intentes aprovechar los fallos detectados. El propósito de RA1 es auditar prevención y cumplimiento. Un resultado del escáner es una evidencia a validar, no una autorización para explotar el sistema.

15.7. Paso 5 · Leer el informe sin limitarse al color

Selecciona hasta cinco resultados representativos. Para cada uno registra: nombre del resultado o VT/NVT, host y puerto si procede, severidad, resumen, evidencia que aporta el escáner y solución propuesta. Si aparece una referencia CVE, anótala, pero no concluyas automáticamente que el puesto es explotable.

Nº	Resultado / NVT	Puerto/servicio	Severidad	Evidencia resumida	Solución indicada
1					
2					
3					
4					
5					

15.8. Paso 6 · Correlacionar Greenbone con WinAudit

La parte esencial de la es comprobar si el hallazgo de red puede relacionarse con la información local de WinAudit. No todos los resultados tendrán correspondencia directa y eso también debe documentarse.

Hallazgo Greenbone	¿Aparece algo relacionado en WinAudit?	Correlación	Conclusión
		Alta / Media / Baja	
		Alta / Media / Baja	
		Alta / Media / Baja	
		Alta / Media / Baja	

Ejemplo metodológico: si WinAudit muestra una herramienta de acceso remoto instalada y Greenbone observa un servicio remoto accesible, las dos evidencias se refuerzan. Si Greenbone detecta un servicio que no aparece claramente en WinAudit, el resultado debe investigarse, no descartarse ni declararse malicioso automáticamente.

15.9. Paso 7 · Valorar el riesgo y el cumplimiento

La severidad técnica del escáner es un dato importante, pero la prioridad de tratamiento depende también del contexto. Para cada hallazgo seleccionado responde:

1. ¿Qué activo o servicio está afectado?
2. ¿Está expuesto y es necesario para la función del puesto?
3. ¿Qué impacto tendría un abuso razonable de la debilidad?
4. ¿Existe una medida compensatoria o el servicio está aislado?
5. ¿Qué requisito P-01 a P-12 resulta afectado?
6. ¿La conclusión es Cumple, Cumple parcialmente, No cumple o No verificable?
7. ¿Qué acción concreta propondrías y cómo demostrarías después que se ha aplicado?

15.10. Paso 8 · Plan de remediación y revalidación

No se modificarán los sistemas salvo indicación expresa. El alumno redactará un plan de tratamiento. Si el laboratorio permite aplicar una corrección sencilla y reversible, podrá repetirse el escaneo para comparar el antes y el después.

Prioridad	Hallazgo	Acción propuesta	Responsable	Verificación posterior
1				
2				
3				

16. Hoja de trabajo

16.1. Datos de Greenbone/OpenVAS

Campo	Valor
Nombre del objetivo	
IP autorizada	
Nombre de la tarea	
Configuración de escaneo	

Campo	Valor
Fecha/hora inicio	
Fecha/hora fin	
Estado de feeds	
Nombre del informe exportado	

16.2. Resumen cuantitativo

Indicador	Valor
Resultados críticos / muy altos si la interfaz los distingue	
Resultados altos	
Resultados medios	
Resultados bajos	
Informativos / logs relevantes	
Hosts escaneados	1

El número total de resultados no equivale al número de vulnerabilidades confirmadas ni determina por sí solo el riesgo del equipo.

16.3. Matriz integrada WinAudit + Greenbone

ID	Evidencia WinAudit	Evidencia Greenbone	Riesgo contextual	Estado	Medida / verificación
P-01					
P-03					
P-04					
P-05					
P-06					
P-09					
P-10					
P-11					
P-12					

17. Cuestiones para el alumno

1. ¿Qué diferencia existe entre el inventario de WinAudit y el escaneo de Greenbone/OpenVAS?

2. ¿Por qué un puerto abierto o un servicio visible no es necesariamente una vulnerabilidad?

3. ¿Por qué un hallazgo con CVE no debe interpretarse automáticamente como “equipo comprometido”?

4. Explica un caso en el que WinAudit y Greenbone hayan aportado evidencias complementarias sobre el mismo elemento.

5. ¿Puede un resultado de severidad baja ser importante para tu organización? Justifica con un ejemplo de contexto.

6. ¿Por qué “0 vulnerabilidades altas” no demuestra por sí solo que el equipo sea seguro?

7. ¿Qué diferencia hay entre severidad técnica y riesgo para la organización?

8. ¿Qué utilidad tiene repetir el escaneo después de una corrección?

9. ¿Qué hallazgo de esta práctica podría convertirse en contenido de un plan de concienciación?

10. Indica tres limitaciones de la práctica y qué evidencias adicionales solicitarías en una auditoría real.

18. Entregables de la

1. Informe WinAudit de la V1.
2. Informe exportado de Greenbone/OpenVAS o capturas justificativas indicadas.
3. Tabla de hasta cinco resultados seleccionados y explicados.
4. Matriz de correlación WinAudit-Greenbone.
5. Matriz de cumplimiento ampliada P-01 a P-12 para los controles evaluados.
6. Plan de remediación con tres acciones prioritarias y su método de verificación.
7. Respuestas a las diez cuestiones .
8. Conclusión ejecutiva conjunta de 10 a 15 líneas: estado del puesto, evidencias principales, límites del análisis y prioridades.

19. Criterios de calidad específicos de la

- El objetivo escaneado está inequívocamente autorizado y documentado.
- El alumno distingue servicio expuesto, hallazgo del escáner, vulnerabilidad y riesgo.
- Las conclusiones no dependen únicamente del color o de la puntuación de severidad.
- Los resultados se correlacionan con WinAudit siempre que sea posible.
- Los falsos positivos o resultados dudosos se marcan para validación, no se presentan como hechos confirmados.
- Las medidas propuestas son concretas, proporcionales y verificables mediante una nueva evidencia o un reescaneo.
- El informe no contiene contraseñas, credenciales ni datos personales innecesarios.

20. Fuentes técnicas para la instalación

Las instrucciones de instalación se han contrastado con documentación disponible en septiembre de 2026. Kali mantiene el paquete gvm y sus scripts; Greenbone advierte de que los paquetes de distribuciones son mantenidos por terceros. Si una versión futura cambia comandos o menús, prevalecerá la documentación de la versión instalada.

- Greenbone Community Documentation · Kali Linux Install Guide:
<https://greenbone.github.io/docs/latest/22.4/kali/index.html>
- Kali Linux Tools · gvm: <https://www.kali.org/tools/gvm/>
- Greenbone Community Documentation · Architecture: <https://greenbone.github.io/docs/latest/architecture.html>
- Greenbone Community Documentation · Community Feed / Workflows:
<https://greenbone.github.io/docs/latest/22.4/container/workflows.html>

ANEXO FINAL · Resolución detallada punto por punto

Cómo utilizar este anexo: La resolución propone respuestas modelo. En las cuestiones que dependen del equipo real, no existe una única lista válida: se indica qué debe observarse, cómo razonarlo y qué conclusión sería correcta en cada caso.

A. Resolución del procedimiento

A.1. Preparación y ejecución

La respuesta correcta debe demostrar que el alumno ha definido primero qué va a comprobar, ha ejecutado WinAudit sin alterar deliberadamente el sistema y ha conservado/exportado el informe. Esto aporta trazabilidad y permite revisar posteriormente las evidencias utilizadas.

A.2. Sistema operativo

- 1) Identificación inequívoca. Debe registrarse la edición y versión de Windows que muestre el informe, junto con el nombre del equipo y otros identificadores técnicos disponibles. No es necesario memorizar nomenclaturas: basta con localizar y documentar correctamente los datos.
- 2) Soporte y actualización. El mero nombre del sistema operativo no demuestra que esté actualizado. Para afirmar cumplimiento se necesitarían datos de versión/build, estado de Windows Update, parches instalados o una fuente de administración equivalente. Si WinAudit no ofrece evidencia suficiente, P-01 puede quedar como “No verificable” o “Cumple parcialmente”, según lo observado.
- 3) Riesgo. Un sistema sin soporte o sin parches puede conservar vulnerabilidades conocidas, carecer de correcciones del fabricante y facilitar explotación, persistencia o escalada de privilegios.

A.3. Usuarios y privilegios

- 1) Número y finalidad. La respuesta debe enumerar las cuentas observadas y diferenciar entre cuentas del sistema, cuentas de usuario y cuentas que requieran justificación. Una cuenta desconocida no se declara maliciosa sin más evidencia.
- 2) Administradores. Deben identificarse las cuentas que pertenecen al grupo de administradores o tienen privilegios elevados. Cuantas más cuentas privilegiadas existan, mayor es la superficie de abuso de credenciales.
- 3) Cuentas a revisar. Ejemplos razonables: cuentas antiguas de personas que ya no utilizan el equipo, cuentas genéricas compartidas, cuentas de prueba o cuentas con privilegios elevados sin justificación.
- 4) Mínimo privilegio. El principio exige asignar únicamente los permisos necesarios para la función. Una cuenta administrativa usada para tareas cotidianas incrementa el impacto potencial de malware, errores o robo de credenciales.

A.4. Software instalado

- 1) Cinco aplicaciones necesarias. Depende del equipo. Serían válidos componentes del sistema, suite ofimática autorizada, navegador corporativo, herramientas de desarrollo si el puesto es técnico, agente de seguridad, etc., siempre que se justifique su función.
- 2) Programas a revisar. Deben seleccionarse por criterios, no por desconocimiento personal: software sin fabricante claro, aplicaciones antiguas, utilidades de acceso remoto no documentadas, herramientas P2P, programas de prueba o software ajeno a la actividad.
- 3) Superficie de ataque. Cada aplicación añade código, librerías, servicios, configuraciones y posibles vulnerabilidades. El software innecesario incrementa puntos potenciales de explotación y dificulta el mantenimiento.

4) Antes de desinstalar. Debe comprobarse propietario funcional, necesidad del puesto, dependencia de otros programas, licencia, criticidad y autorización del responsable. Una auditoría propone; no debe eliminar software sin procedimiento.

A.5. Servicios

- 1) Tres servicios. La respuesta debe nombrar servicios visibles y explicar su función de forma prudente. Es válido indicar “servicio asociado a X aplicación” si se ha verificado el fabricante o la relación con el software instalado.
- 2) Servicio a revisar. Debe justificarse por anomalía: nombre/fabricante desconocido, relación con software no autorizado, escucha o acceso remoto, persistencia innecesaria o ausencia de función aparente.
- 3) No detener durante la auditoría. Cambiar el estado de un servicio altera el sistema auditado, puede afectar a usuarios y aplicaciones, destruye parte de la reproducibilidad y puede provocar pérdida de evidencia o indisponibilidad.

A.6. Red

- 1) Adaptadores. Deben registrarse los físicos y virtuales que aparezcan: Ethernet, Wi-Fi, VPN, Hyper-V/VMware/VirtualBox, Bluetooth u otros.
- 2) Coherencia. Se compara con el contexto. En una máquina virtual es normal encontrar adaptadores virtuales; en un puesto de oficina podrían requerir explicación varias VPN o interfaces de software de virtualización no autorizado.
- 3) Elementos a justificar. Una VPN no es insegura por definición; un adaptador virtual tampoco. El hallazgo correcto es “requiere validación frente a la configuración autorizada”.
- 4) Datos útiles en incidentes. IP, MAC, hostname, interfaces, DNS, gateway y configuración de red pueden ayudar a correlacionar logs, identificar el equipo y reconstruir comunicaciones.

A.7. Controles de seguridad

- 1) Antimalware. Solo puede afirmarse que existe y está operativo si la evidencia lo demuestra. Si WinAudit muestra producto pero no estado/actualización, la conclusión debe matizarse.
- 2) Firewall. Igual criterio: la existencia de un componente no demuestra que esté habilitado con una política adecuada.
- 3) “No mostrado” frente a “no existente”. La primera frase describe una limitación de evidencia; la segunda es una conclusión sobre el sistema. Confundir ambas conduce a falsos incumplimientos.
- 4) Segunda fuente. Para antivirus: Seguridad de Windows, consola EDR/antivirus o PowerShell autorizado. Para firewall: Windows Defender Firewall, directivas de grupo, consola de administración o comandos de consulta permitidos.

A.8. Matriz de cumplimiento: ejemplo resuelto

El siguiente ejemplo es orientativo. Debe sustituirse por los datos reales del equipo analizado.

ID	Evidencia	Estado	Riesgo	Medida
P-01	Windows identificado; WinAudit no confirma estado completo de parches.	Cumple parcialmente	Exposición a vulnerabilidades si faltan actualizaciones.	Verificar Windows Update o consola de gestión y aplicar parches aprobados.
P-02	Se observan 4 cuentas; una cuenta genérica “pruebas” requiere justificación.	Cumple parcialmente	Cuenta innecesaria puede facilitar acceso no trazable.	Validar propietario y deshabilitar/eliminar si no es necesaria.
P-03	Software principal justificado; aparece una utilidad remota no documentada.	Cumple parcialmente	Acceso remoto no autorizado puede aumentar superficie de ataque.	Confirmar autorización, versión y necesidad; retirar si no procede.
P-04	Servicios del sistema y terceros; uno asociado a la utilidad remota.	Cumple parcialmente	Persistencia o exposición innecesaria.	Validar servicio y deshabilitar solo tras aprobación si no es necesario.
P-05	Ethernet y adaptador virtual detectados; virtualización no documentada.	Cumple parcialmente	Configuración fuera de inventario.	Confirmar necesidad del adaptador y documentarlo.

ID	Evidencia	Estado	Riesgo	Medida
P-06	Producto antimalware visible; estado del firewall no concluyente.	No verificable	No se puede demostrar cobertura completa.	Comprobar estado en Seguridad de Windows o consola corporativa.
P-07	Inventario generado correctamente y equipo identificado.	Cumple	Bajo.	Conservar inventario y programar revisiones periódicas.
P-08	Dos cuentas administrativas; una requiere justificación.	Cumple parcialmente	Exceso de privilegios aumenta impacto de compromiso.	Revisar membresía y aplicar mínimo privilegio.

A.9. Medidas correctoras: cómo redactarlas

Una medida correctora de calidad debe responder a cuatro preguntas: qué se va a cambiar, quién debe autorizarlo o ejecutarlo, qué riesgo reduce y cómo se verificará después. “Mejorar la seguridad” no es una medida válida por ser demasiado genérica.

Hallazgo débil	Medida débil	Medida correctamente formulada
Cuenta genérica sin propietario claro	Eliminarla	Identificar propietario y uso; si no existe necesidad aprobada, deshabilitarla y posteriormente eliminarla conforme al procedimiento de gestión de identidades. Verificar que ya no aparece en el inventario.
Software remoto no documentado	Quitar el programa	Confirmar con el responsable si la herramienta está autorizada. Si no lo está, desinstalarla por el procedimiento corporativo y comprobar que su servicio asociado y la aplicación ya no aparecen.
Estado del firewall no verificable	Activar firewall	Verificar primero el estado y la política aplicada con la consola o herramienta corporativa. Si está deshabilitado sin excepción autorizada, habilitar la política aprobada y documentar la comprobación.

B. Resolución de las cuestiones finales

1. Herramienta frente a cumplimiento

WinAudit recopila información del equipo, pero una auditoría necesita un criterio de comparación. Saber que hay 35 programas instalados no indica si hay incumplimiento hasta conocer qué software está autorizado. La herramienta aporta evidencia; la política aporta el requisito; el auditor formula la conclusión.

2. Hallazgo, evidencia y medida correctora

Ejemplo: evidencia: WinAudit muestra una cuenta “pruebas” dentro de administradores. Hallazgo: existe una cuenta privilegiada cuya necesidad no está documentada. Medida: validar el propietario y, si no se justifica, retirar privilegios o deshabilitarla siguiendo el procedimiento. El hallazgo interpreta una evidencia frente a un requisito.

3. Riesgo de una cuenta administrativa adicional

Aunque no haya incidente, una cuenta privilegiada amplía las credenciales que pueden ser robadas o abusadas. También dificulta la trazabilidad si es compartida. Por eso debe justificarse y aplicarse mínimo privilegio.

4. No visible no equivale a no cumple

La herramienta puede carecer de permisos, no soportar una fuente concreta o no mostrar el estado detallado del control. La conclusión correcta es “No verificable” hasta obtener una segunda evidencia. Marcar “No cumple” sin prueba sería metodológicamente incorrecto.

5. Tres evidencias útiles en auditorías periódicas

Una buena selección sería: inventario de software, cuentas y grupos privilegiados, y servicios/configuración relevante del sistema. También pueden ser válidos sistema operativo/parches y configuración de red si se justifica su utilidad para detectar desviaciones entre revisiones.

6. Elementos útiles para detectar/investigar incidentes

Usuarios privilegiados, software de acceso remoto, servicios desconocidos, configuración de red, hostname, IP, aplicaciones instaladas y cambios entre inventarios pueden convertirse en pistas o contexto útil en RA2/RA3. La práctica de RA1 crea una línea base contra la que después detectar anomalías.

C. Modelo de conclusión ejecutiva

Ejemplo: El puesto analizado presenta un nivel de cumplimiento parcial respecto a la baseline establecida. El sistema ha podido inventariarse correctamente y la mayor parte del software observado parece coherente con su función. No obstante, se ha identificado una cuenta privilegiada cuya necesidad debe justificarse, una utilidad de acceso remoto no documentada y ausencia de evidencia suficiente para confirmar el estado del firewall. Estas situaciones no demuestran por sí mismas un incidente, pero incrementan el riesgo y deben revisarse. Se prioriza: 1) validar las cuentas con privilegios administrativos; 2) confirmar la autorización de la herramienta remota y su servicio asociado; y 3) verificar el estado real del firewall mediante una segunda fuente. Tras aplicar las medidas aprobadas, deberá repetirse la comprobación y actualizarse el inventario del puesto.

D. Aspectos a Valorar

Aspecto	Indicador de logro
Uso de la herramienta	Obtiene y conserva el informe sin alterar deliberadamente el sistema.
Interpretación	Distingue inventario bruto de evidencia relevante.
Cumplimiento	Relaciona cada requisito con una evidencia concreta y una conclusión justificable.
Rigor	Utiliza “No verificable” cuando faltan datos y evita afirmaciones no demostradas.
Medidas	Propone acciones concretas, proporcionales y verificables.
Comunicación	Resume hallazgos y prioridades con lenguaje técnico claro.

E. Resolución de la práctica con Greenbone/OpenVAS

E.1. Preparación del laboratorio

La solución correcta debe mostrar que el objetivo utilizado es exclusivamente el Windows autorizado y que las dos máquinas comparten una red de laboratorio. El alumno debe registrar la IP antes del escaneo. No se aceptan rangos externos ni “escaneos de prueba” contra direcciones no autorizadas.

Si el ping no responde, la conclusión correcta no es “el equipo está apagado”. Debe revisarse la conectividad, el adaptador de red y el firewall. En Windows es habitual que ICMP pueda estar filtrado aunque existan servicios TCP accesibles.

E.1.1. Dónde se ejecuta cada herramienta y cómo se conectan

WinAudit y Greenbone/OpenVAS analizan el mismo puesto desde perspectivas diferentes. WinAudit se ejecuta localmente en la máquina Windows que se está auditando. Normalmente puede utilizarse como herramienta portable, por lo que no requiere una instalación tradicional: se copia o se pone a disposición el ejecutable y se lanza en el propio Windows. Greenbone/OpenVAS, en cambio, se ejecuta en Kali Linux y analiza el equipo Windows a través de la red, utilizando la dirección IP del objetivo autorizado.

Equipo	Ejemplo de IP	Herramienta / función
Kali Linux	192.168.56.10	Greenbone/OpenVAS. Actúa como escáner y origina las comprobaciones de red.
Windows auditado	192.168.56.20	WinAudit se ejecuta localmente. Es el objetivo autorizado de Greenbone/OpenVAS.
Red de laboratorio	192.168.56.0/24	Host-only o red interna del hipervisor. Aísla la práctica de la red real del centro.

Topología recomendada: Windows auditado ← red Host-only / interna → Kali con Greenbone/OpenVAS. Kali puede tener un segundo adaptador NAT solo para actualizar paquetes y feeds. El objetivo de escaneo será únicamente la IP del Windows asignado para la práctica.

E.1.2. Qué ve cada herramienta

Aspecto	WinAudit (visión local)	Greenbone/OpenVAS (visión de red)
Lugar de ejecución	Dentro del Windows auditado	En Kali Linux
Instalación/agente	Portable; normalmente sin instalación tradicional	No necesita instalar un agente en Windows para un escaneo no autenticado
Inventario	Muy útil para software, usuarios, servicios, hardware y configuración	Limitado a lo que puede inferirse o comprobarse desde el escáner
Exposición de red	Aporta contexto local, pero no sustituye una comprobación remota	Detecta puertos, servicios y protocolos accesibles desde Kali
Vulnerabilidades	Permite formular hipótesis por versiones/configuraciones	Ejecuta pruebas NVT y genera hallazgos, severidad y referencias
Uso didáctico	¿Qué tengo y cómo está configurado?	¿Qué está expuesto y qué debilidades se detectan desde la red?

La correlación es esencial. Por ejemplo, si WinAudit muestra que existe un servicio FTP pero Greenbone no observa el puerto 21 accesible, no existe necesariamente una contradicción: el servicio puede estar detenido, filtrado por el firewall o limitado a otra interfaz. Si ambos confirman el mismo servicio, la evidencia es más sólida y puede analizarse su necesidad, exposición y posible vulnerabilidad.

E.1.3. Conectividad y creación del objetivo

Antes del escaneo, ambas máquinas deben poder comunicarse en la red de laboratorio. Puede comprobarse la configuración IP y, como prueba orientativa, ejecutar ping desde Kali hacia Windows. Un ping sin respuesta no demuestra que el host sea inaccesible: Windows puede bloquear ICMP en el firewall. La comprobación definitiva se realiza verificando que el objetivo es alcanzable para las pruebas permitidas por el escáner.

Paso	Acción	Resultado esperado
1	Identificar la IP del Windows (ej.: 192.168.56.20).	Se conoce el único objetivo autorizado.
2	Desde Kali, verificar que está en la misma red y revisar conectividad.	La ruta/red de laboratorio es correcta.
3	En Greenbone, crear un Target con la IP de Windows.	El objetivo queda registrado.
4	Crear una Task con una configuración como Full and fast.	La tarea apunta únicamente al Target autorizado.
5	Ejecutar el escaneo y conservar el informe.	Se obtiene evidencia para correlacionar con WinAudit.

E.1.4. Escaneo no autenticado y autenticado

En un escaneo no autenticado, Greenbone examina Windows como otro equipo de la red: identifica superficie accesible y realiza comprobaciones remotas sin disponer de credenciales del sistema. Es apropiado para la primera toma de contacto del alumnado. En un escaneo autenticado, Greenbone utiliza credenciales específicamente autorizadas para obtener información interna adicional, como versiones, parches o determinadas configuraciones. Esta segunda modalidad se ajusta especialmente a la cláusula de la política corporativa que exige escaneos autenticados mensuales.

En clase: comenzar con un escaneo no autenticado para comprender la superficie de ataque. Si el entorno está preparado, realizar después un escaneo autenticado con una cuenta de laboratorio creada para ese fin y comparar qué información adicional aparece. Nunca se utilizarán credenciales reales ni se ampliará el alcance a sistemas no autorizados.

E.2. Instalación

Secuencia esperada en Kali: actualización del sistema; instalación del metapaquete gvm; ejecución de gvm-setup; conservación segura de la contraseña admin; comprobación con gvm-check-setup; arranque con gvm-start; acceso local a la interfaz y verificación de feeds. No debe iniciarse un escaneo mientras la instalación esté incompleta o los objetos de datos esenciales sigan sin importarse.

```

sudo apt update
sudo apt upgrade -y
sudo apt install gvm -y
sudo gvm-setup
sudo gvm-check-setup
sudo gvm-start

```

La respuesta de un alumno que copia los comandos sin explicar su finalidad es incompleta. Debe entender que gvm-setup configura servicios, base de datos, credenciales y datos necesarios; gvm-check-setup comprueba la preparación; gvm-start inicia los servicios.

E.3. Creación del Target y de la tarea

El Target debe contener una única IP autorizada. La tarea debe vincular ese Target con el escáner y una configuración de análisis indicada, normalmente Full and fast para esta práctica. Debe quedar registrada la fecha/hora y el estado final del escaneo. Si el alumno configura accidentalmente un rango mayor, debe detener la tarea y comunicarlo.

E.4. Cómo interpretar un resultado

Una respuesta de calidad separa cuatro capas: 1) observación técnica del escáner; 2) posible vulnerabilidad o mala configuración; 3) riesgo contextual; 4) requisito de política y acción. El escáner puede producir falsos positivos o resultados que requieren comprobación adicional.

Capa	Ejemplo de respuesta correcta
Observación	El escáner informa de un servicio accesible en un puerto concreto y genera un resultado asociado.
Vulnerabilidad/debilidad	El resultado indica una versión o configuración que podría estar afectada; debe validarse con la evidencia disponible.
Riesgo	Si el servicio es accesible y vulnerable, podría aumentar la probabilidad o impacto de acceso no autorizado. El riesgo depende del contexto.
Cumplimiento	Se compara con P-09/P-10 y se documenta Cumple, Parcial, No cumple o No verificable.
Tratamiento	Actualizar, reconfigurar, restringir exposición o aceptar justificadamente el riesgo; después verificar.

F. Ejemplo integrado resuelto WinAudit + Greenbone

Escenario simulado: Los siguientes datos son deliberadamente genéricos para que la solución siga siendo válida con distintas versiones. El alumnado debe sustituirlos por sus evidencias reales.

#	WinAudit	Greenbone	Riesgo	Control	Estado	Medida/verificación
1	WinAudit muestra una herramienta de acceso remoto instalada y un servicio asociado.	Greenbone observa el servicio remoto accesible desde la red de laboratorio.	Alta	P-04 / P-09	Cumple parcialmente	Confirmar autorización y necesidad; restringir exposición si no debe ser accesible desde esa red; repetir comprobación.
2	WinAudit identifica una aplicación de servidor con versión visible.	Greenbone genera un hallazgo de severidad alta asociado a una versión vulnerable o potencialmente vulnerable.	Alta	P-03 / P-10	No cumple hasta validación/corrección	Validar versión exacta, aplicar actualización aprobada o medida compensatoria y reescanear.

#	WinAudit	Greenbone	Riesgo	Control	Estado	Medida/verificación
3	WinAudit no aporta evidencia suficiente sobre un servicio TLS.	Greenbone informa de un problema de certificado o configuración TLS de severidad baja/media.	Media	P-06 / P-10	Cumple parcialmente / No verificable	Revisar configuración y política TLS. No elevar prioridad solo por el nombre del hallazgo; valorar uso del servicio y exposición.
4	WinAudit muestra varios servicios del sistema.	Greenbone no identifica vulnerabilidades relevantes en ellos.	Media-baja	P-04 / P-10	No concluyente por sí solo	Mantener inventario y actualizaciones. La ausencia de hallazgos no demuestra ausencia total de vulnerabilidades.
5	WinAudit muestra un adaptador/red de laboratorio correctamente documentado.	Greenbone alcanza únicamente la IP autorizada.	Baja	P-05 / P-12	Cumple	Conservar evidencia de la topología y repetir en auditorías posteriores.

F.1. Por qué el caso 2 puede ser prioritario

La prioridad no se asigna únicamente porque el escáner marque “alta”. La correlación local confirma que el software está realmente instalado y el análisis de red indica que existe superficie accesible. La combinación de evidencia local + exposición + severidad hace que el hallazgo merezca atención prioritaria. Aun así, debe validarse la versión exacta y la aplicabilidad del resultado antes de afirmar explotación posible.

F.2. Por qué el caso 4 no equivale a “equipo seguro”

Un escaneo es una fotografía limitada por la visibilidad de red, la configuración, los feeds, las credenciales utilizadas y las pruebas disponibles. Puede no observar vulnerabilidades locales, problemas de privilegios o configuraciones que WinAudit sí permite contextualizar. “No encontrado” significa únicamente que esa ejecución no produjo el hallazgo.

G. Resolución de las cuestiones

1. Inventario frente a escaneo

WinAudit inspecciona información local del equipo y genera inventario/configuración. Greenbone/OpenVAS observa y prueba el objetivo desde el escáner, principalmente a través de la red, y compara respuestas con pruebas de vulnerabilidad. Son evidencias diferentes y complementarias.

2. Puerto abierto no equivale a vulnerabilidad

Un puerto abierto indica que un servicio escucha y es alcanzable. Puede ser necesario, estar actualizado y correctamente protegido. Se convierte en problema cuando la exposición no está justificada o el servicio presenta una debilidad relevante.

3. CVE no equivale a compromiso

Una referencia CVE describe una vulnerabilidad conocida; no demuestra que haya sido explotada ni que el equipo esté comprometido. Debe verificarse versión, configuración, aplicabilidad y contexto.

4. Evidencias complementarias

Ejemplo: WinAudit identifica software de acceso remoto y su servicio; Greenbone confirma que el servicio es visible desde la red. Juntas permiten valorar mejor el control P-09 que cualquiera de las dos por separado.

5. Severidad baja con impacto contextual

Un hallazgo bajo puede ser relevante si afecta a un activo muy sensible, revela información útil para un atacante, viola una obligación concreta o se combina con otras debilidades. El contexto puede elevar su prioridad interna.

6. Cero altas no demuestra seguridad

El escáner tiene límites de visibilidad, cobertura y configuración. También existen debilidades de usuarios, procesos, software no expuesto, ingeniería social o configuración local que un escaneo no necesariamente detecta.

7. Severidad técnica frente a riesgo

La severidad estima características técnicas del hallazgo. El riesgo incorpora además exposición, probabilidad, valor del activo, impacto para la organización y controles compensatorios.

8. Reescaneo

Permite obtener nueva evidencia tras el tratamiento. Si el hallazgo desaparece y el control está correctamente configurado, se mejora la trazabilidad de la corrección. Si persiste, hay que revisar la medida o la interpretación.

9. Relación con concienciación

Ejemplos: software no autorizado, herramientas remotas instaladas por usuarios, falta de actualizaciones o prácticas de mínimo privilegio pueden convertirse en mensajes o actividades de concienciación.

10. Limitaciones

Son válidas, entre otras: escaneo sin credenciales, dependencia de feeds, falsos positivos/negativos, visibilidad condicionada por firewall, fotografía temporal y ausencia de contexto de negocio. Evidencias adicionales: gestión de parches, EDR, políticas, inventario corporativo, logs y validación manual autorizada.

H. Modelo de conclusión ejecutiva

Ejemplo: La auditoría combinada muestra que el inventario local obtenido con WinAudit y el análisis de Greenbone/OpenVAS aportan perspectivas complementarias. El puesto presenta varios servicios y aplicaciones identificados correctamente, pero se ha localizado al menos un elemento cuya exposición de red debe justificarse y un hallazgo de vulnerabilidad que requiere validar la versión afectada y priorizar su tratamiento. La severidad indicada por el escáner se ha contextualizado con la función del puesto y la evidencia local, evitando considerar automáticamente cada resultado como una vulnerabilidad explotable. Las acciones prioritarias son validar el software afectado, aplicar la actualización o medida compensatoria aprobada y reducir la exposición de servicios no necesarios. Tras las correcciones debe repetirse el análisis y conservarse el nuevo informe como evidencia de cierre. La ausencia de hallazgos críticos en un escaneo posterior no sustituye a la revisión periódica de inventario, privilegios y controles del puesto.

I. Aspectos de la evaluación

Bloque	Qué se espera
Preparación y autorización	Identifica correctamente el objetivo y trabaja solo en la red de laboratorio.
WinAudit	Conserva la evidencia V1 y selecciona datos relevantes para formular hipótesis.
Greenbone	Configura el Target y la tarea sin ampliar el alcance y obtiene un informe trazable.
Interpretación	Distingue exposición, vulnerabilidad, severidad y riesgo.
Correlación	Relaciona resultados de ambas herramientas con prudencia y explica discrepancias.
Cumplimiento	Vincula evidencias con P-01 a P-12 y justifica el estado asignado.
Remediación	Propone acciones específicas y define cómo verificar su cierre.
Comunicación	Redacta una conclusión ejecutiva breve, técnica y sin afirmaciones no demostradas.

J. Resolución · Cómo auditar la política corporativa de GalileoTechSolutions

La siguiente matriz muestra qué tipo de evidencia sería adecuada para cada bloque de la política. Su finalidad es que el alumnado comprenda que WinAudit y Greenbone/OpenVAS cubren una parte importante de la auditoría técnica, pero no pueden demostrar por sí solos el cumplimiento integral de una política corporativa.

Bloque de política	Qué se debe demostrar	WinAudit	OpenVAS	Evidencia adicional	Interpretación
1. Introducción y alcance	Revisión documental: alcance aprobado, aceptación/NDA y relación de colectivos incluidos.	No	No	Revisión documental / RR. HH.	No debe marcarse "Cumple" solo porque el equipo sea técnicamente seguro.
2. Roles y responsabilidades	Existencia de CSI, funciones asignadas y evidencias de revisión/auditoría.	No	No	Organigrama, actas, procedimientos.	Control de gobierno, no técnico.
3.1 Correo e Internet	Uso profesional, prohibición de reenvío a cuentas personales y filtrado web.	Parcial	Parcial	Proxy/SWG, correo, DLP, registros.	WinAudit puede mostrar clientes/software; OpenVAS no demuestra el comportamiento del usuario.
3.2 Mesa/pantalla limpia	Ausencia de documentación expuesta y bloqueo de sesión.	Parcial	No	Inspección física + GPO/política de bloqueo.	El bloqueo automático puede verificarse por configuración; la mesa limpia requiere observación.
3.3 USB y almacenamiento	Bloqueo de USB personales y uso de nube autorizada.	Parcial	No	GPO/MDM/EDR, registros USB, configuración corporativa.	WinAudit aporta contexto, pero no acredita por sí solo todos los accesos históricos.
4. Identidades y acceso	Contraseñas, MFA, mínimo privilegio y cuentas administrativas.	Parcial	No/Parcial	AD/GPO/IdP/VPN + WinAudit para cuentas locales.	WinAudit es muy útil para privilegios locales; MFA requiere la plataforma de identidad.
5. Hardening	Cifrado, bloqueo automático, protocolos inseguros y EDR activo.	Parcial/Alta	Parcial/Alta	WinAudit, PowerShell/GPO, OpenVAS y consola EDR.	La combinación local + remota permite una comprobación más sólida.
6. Vulnerabilidades y actualizaciones	Escaneo mensual, parches y SLA de remediación por CVSS.	Parcial	Alta	Greenbone/OpenVAS + gestión de parches + tickets/SLA.	Es el bloque donde OpenVAS tiene mayor relación directa con RA1-e.
7. Teletrabajo	VPN, MFA, prohibición de Wi-Fi sin VPN y control de BYOD.	Parcial	No	VPN, IdP, MDM y registros de acceso.	Requiere evidencias corporativas adicionales.
8. Clasificación de información	Etiquetado, tratamiento y cifrado de información restringida.	No/Parcial	No	DLP, etiquetas, procedimientos, revisión de ficheros.	La clasificación es un control organizativo y técnico más amplio.
9. Gestión de incidentes	Canal de reporte y procedimiento de desconexión/preservación.	No	No	Procedimiento, simulación, entrevistas, tickets.	Se evalúa mejor mediante ejercicios de concienciación y respuesta.
10. Cumplimiento	Monitorización y de tratamiento de incumplimientos.	Parcial	Parcial	SIEM/EDR, auditorías, RR. HH., procedimientos.	Las herramientas aportan evidencias, pero el régimen disciplinario es documental/organizativo.

J.1. Ejemplo de resolución integrada

Supuesto: WinAudit identifica una aplicación de servidor y un servicio activo. Greenbone, desde Kali, detecta el puerto correspondiente y genera un hallazgo de severidad alta asociado a una versión potencialmente vulnerable. La política exige software actualizado, servicios justificados y remediación de vulnerabilidades altas en un máximo de 7 días. La conclusión no debe limitarse a copiar el CVSS: el alumno debe verificar la versión, justificar la exposición, clasificar el incumplimiento, proponer la actualización o medida compensatoria y planificar un reescaneo que demuestre la corrección.

J.2. Regla de decisión para la matriz de cumplimiento

Estado	Cuándo usarlo	Ejemplo
--------	---------------	---------

Estado	Cuándo usarlo	Ejemplo
Cumple	Existe evidencia suficiente que demuestra el requisito.	Servicio prohibido no instalado ni accesible y configuración verificada.
Cumple parcialmente	El control existe, pero hay una desviación o evidencia incompleta.	EDR detectado, pero no se confirma actualización de firmas.
No cumple	La evidencia confirma una desviación de la política.	Greenbone detecta FTP accesible cuando la política exige que esté deshabilitado.
No verificable	WinAudit/OpenVAS no aportan evidencia suficiente.	MFA obligatorio: requiere revisar el proveedor de identidad o la VPN.